



Retail Trade **Threat Landscape** Report

Reporting Period: January 1 to March 31, 2026

Ransomware & Data-Leak Sites

Ransomware remains a top cyber threat to all organizations globally. This section showcases the top ransomware groups targeting the retail trade sector and what you can do about them.

115

ransomware attacks

▼ 21%

since last reporting period
(October 1 to December 31, 2025)

Key Points and Recommendations

- Overall retail trade victims posted to data-leak sites increased slightly in the latest period, while activity among the top ransomware groups became more evenly distributed as "Qilin" held steady and both "Akira" and "The Gentlemen" increased their share of postings.
- "Clop" and "Scattered Lapsus\$ Hunters" (SLH) dropped out of the top five, reflecting slight shifts among the most active groups. However, SLH remained highly active with vishing campaigns in Q1 2026 and continued to pose a significant threat.
- Akira increased its activity in the quarter, and recent reporting linked the group to search engine optimization (SEO) poisoning campaigns using trojanized software installers impersonating legitimate applications as a potential initial access path for follow-on ransomware deployment.
- Against Qilin and Akira, prioritize rapid patching of edge appliances, reset exposed VPN credentials, enforce phishing-resistant MFA for remote access, and use application allowlisting to block trojanized installers from SEO poisoning. Monitor for PsExec, WinRM, VPN logins from Virtual Private Server (VPS)-hosted infrastructure, and anomalous installer downloads.

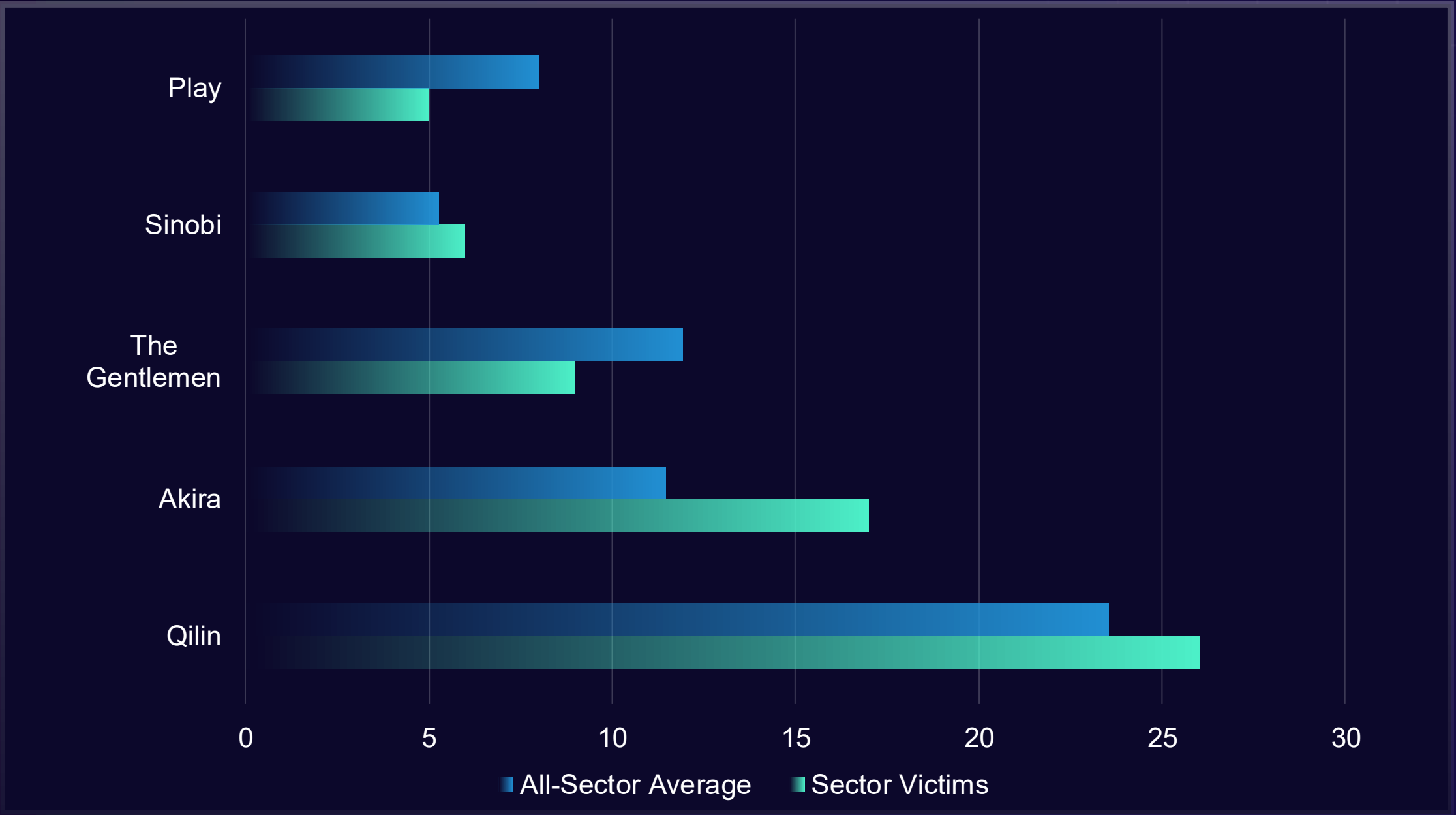


Figure 1: Number of retail trade organizations named on data-leak sites vs. the average number of organizations named to data-leak sites across all sectors.

Vulnerability Exploitation

This section explores trends in vulnerability exploitation. It details how quickly attackers are exploiting vulnerabilities, which vulnerabilities are most discussed by cybercriminals and researchers, and key incidents from the reporting period.

The most recent quarter saw average time-to-exploitation rise to 13 days across 41 vulnerabilities, up 61% from 8 days across 46 the prior quarter, likely indicating a shift toward more complex, higher-value targets rather than easy opportunities. Rapid exploitation also declined, with same-day exploitation dropping from 21 to 10 CVEs and five-day exploitation from 28 to 20, suggesting fewer flaws were immediately or easily exploitable. Key examples include CVE-2026-20963, a Microsoft SharePoint remote-code execution (RCE) exploited by multiple threat actors, and CVE-2026-21643, a pre-auth SQL injection in Fortinet FortiClient Endpoint Management Server (EMS) that enables unauthenticated code execution, both likely favored for their broad enterprise exposure.

Popular CVEs

CVE	ReliaQuest Intelligence Mentions
CVE-2026-21509 - Microsoft Office RCE vulnerability	16
CVE-2026-20045 - Cisco Unified Communications critical vulnerability	7
CVE-2026-1731 - BeyondTrust Remote Support Critical vulnerability	6
CVE-2026-24858 - Fortinet FortiOS Critical vulnerability	6
CVE-2025-55182 - React Server Document Object Model (DOM) Critical flaw	6



Vulnerability Highlights

CVE-2026-33634

CVE-2026-33634 is a CVSS 6.3 embedded malicious code vulnerability in Aqua Security's trivy-action and setup-trivy GitHub Actions. Exploited in the wild since March 19, 2026, the threat actor "TeamPCP" used compromised credentials to inject credential-stealing malware into the tools' version tags, harvesting continuous integration/continuous delivery (CI/CD) pipeline secrets at scale. This incident has since entered a ransomware phase, with the "Vect" ransomware group confirmed as using stolen credentials from this supply-chain compromise to target victims.

Organizations using these tools in their CI/CD pipelines are at direct risk of credential and secrets theft, which can expose cloud environments and downstream systems. A clean version, setup-trivy v0.2.6, is available. Immediately upgrade, rotate all secrets exposed in affected pipelines, and pin GitHub Actions to a specific commit hash rather than mutable version tags per Aqua Security's advisory.

Attacker Target Insights

This section details the initial access attempts that are targeting ReliaQuest’s retail trade customers. It also explores how quickly organizations in the sector are responding to threat actor activity. Our agentic AI security operations platform, GreyMatter, allows threats to be detected at the source and in transit. Security teams can contain, investigate, and respond in less than 5 minutes—eliminating Tier 1 and Tier 2 security operations work.

How fast did retail trade organizations respond to cyber threats?

The mean time to contain (MTTC) improved to 2 hours and 12 minutes during the reporting period. This was down from 6 hours and 58 minutes since the last reporting period, a decrease of approximately 68%. This suggests organizations in this industry are responding to threats more quickly, which is especially important as attacks continue to accelerate.



During the reporting period, organizations in retail trade using Automated Response Playbooks achieved an average MTTC of 5 minutes. This indicates very rapid containment for threats handled through automated workflows.

Top Techniques

According to our customer incident data, attacks targeting the retail trade sector increased by 241% during the reporting period.

The way attackers operated also shifted noticeably. Compared with the previous period, there was less reliance on email-based intrusion methods, with phishing techniques combined falling to 9% from 22%. Spearphishing Links also dropped sharply, and there was less observed use of Public-Facing Application Exploitation and Cloud-account Abuse.

In contrast, attackers appeared to spend more time identifying reachable systems and network information than trying to gain access through remote administration tools, remote desktop technologies, Virtual Network Computing (VNC), and password guessing. Taken together, this points to a broader focus on finding exposed entry points and using remote access or weak credentials to establish a foothold.

Top MITRE Techniques Targeting Sector

MITRE ATT&CK Technique	Percentage of All Techniques Observed
Gather Victim Network Information	19
IP Addresses	19
External Remote Services	17
Phishing for Information	4
Spearphishing Link	2

Digital Risk Protection

This section explores the biggest GreyMatter Digital Risk Protection (DRP) risks to the retail trade sector. If a risk is detected, customers receive context-rich alerts via the GreyMatter alert process, with clear response steps including assignment and mitigation recommendations.

Credential exposure remained the leading alert type across retail trade by a wide margin, despite declining sharply from the previous period. Meanwhile, impersonating domains and expired certificates gained share, while impersonating subdomains declined. This points to a broader risk mix, but stolen credentials remain a key near-term concern because they can enable account takeover and follow-on fraud, a common access path for financially motivated actors such as “ShinyHunters.”

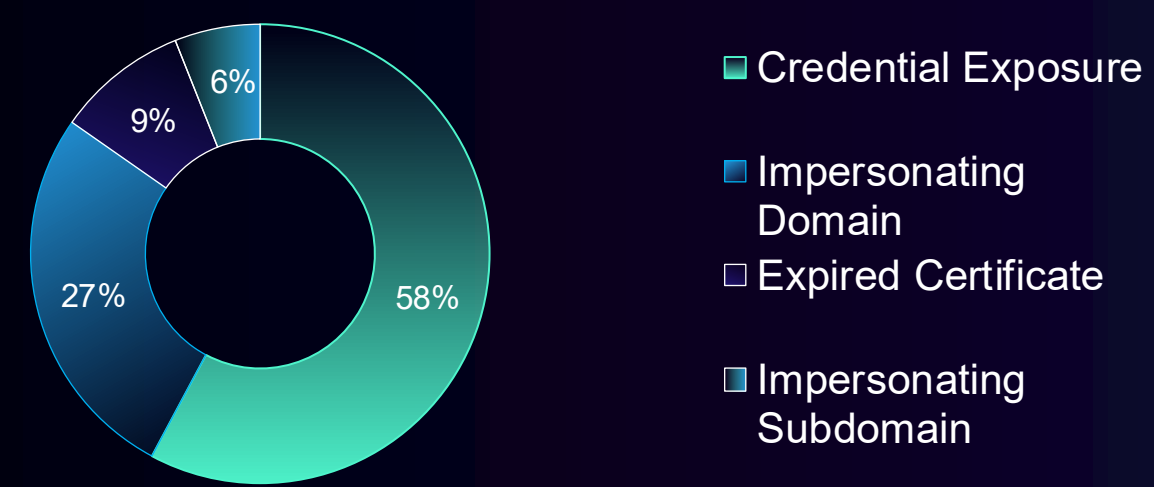


Figure 2: *DRP alerts by type for retail trade customers this reporting period*

All-Sector Top DRP Alerts (for comparison)

Risk Type	Percentage
Credential Exposure	30
Impersonating Domain	24
Impersonating Subdomain	18
Selling Unauthorized Goods	7
Expired Certificate	6

Countries Targeted

Publicly known cyber events targeting organizations in retail trade remained centered on the US, despite a modest 7% decline in alerts; it still accounted for 48% of activity, reinforcing that large, digitally dependent US retailers remain the highest-value targets for ransomware and data-theft operations. Canada and Australia each saw sharp increases of 150% and 75%, while Mexico rose by 150%, suggesting broader focus on North American and allied English-speaking markets. Germany was broadly stable, but Japan fell 71%, indicating no sustained pivot into East Asia. Most smaller-country movement appears consistent with opportunistic targeting rather than a durable shift.

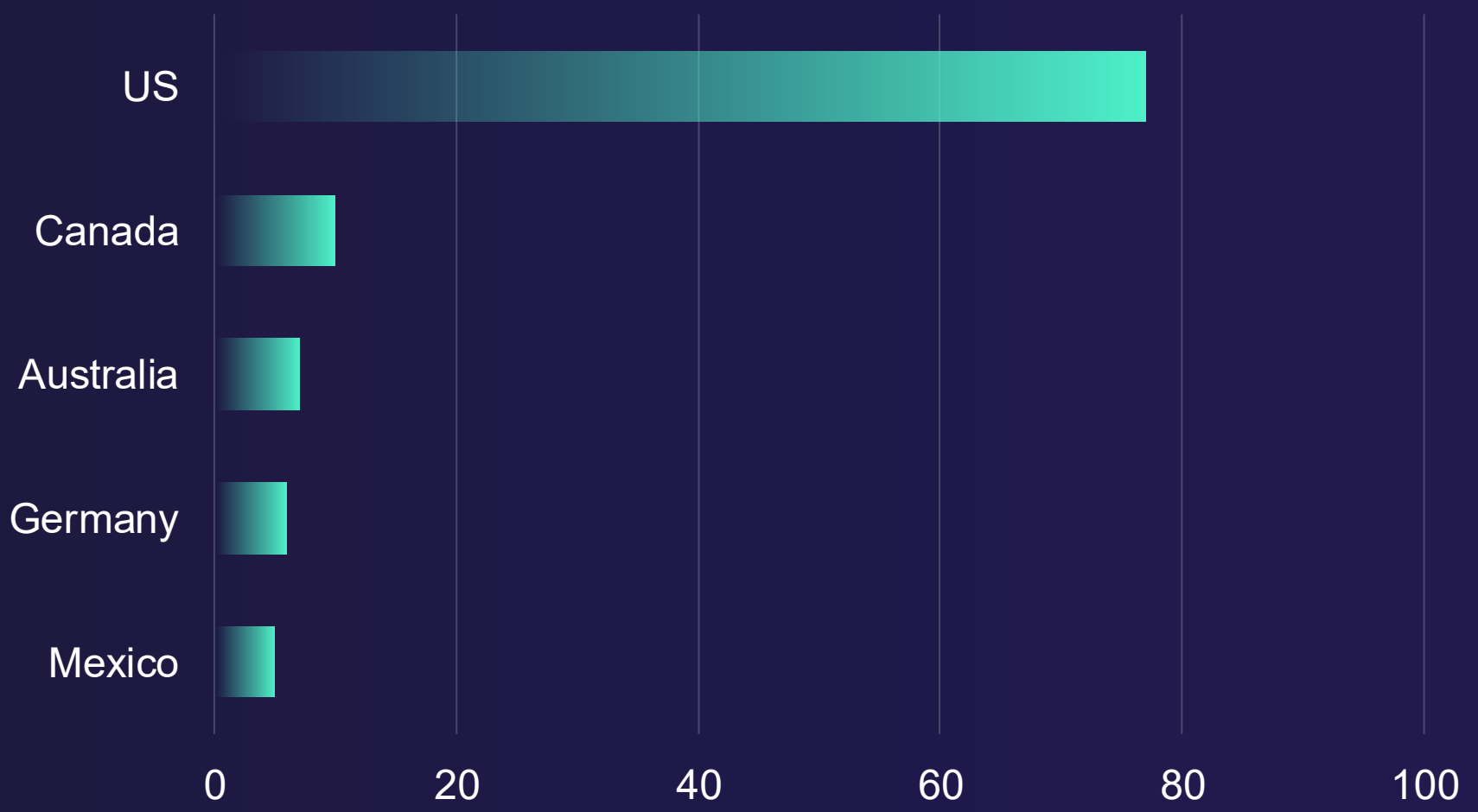


Figure 3: *Number of significant cyber events, by region*

Notable Developments

Axios Supply-Chain Attack Hits Retail

Compromised Axios npm releases installed the "WAVESHAPER.V2" remote access trojan through a hidden dependency on macOS, Windows, and Linux. For retail trade, websites, payment apps, and internal Node.js tools using the library faced silent malware delivery, credential theft, and broad downstream exposure from a widely used JavaScript dependency.

[Read More](#)

■ March 31, 2026

Microsoft 365 Token Abuse Threat

Device code phishing is compromising Microsoft 365 accounts by stealing valid tokens, enabling persistent access, mailbox compromise, and business email compromise. For retail trade, this threatens executive and employee email, increases fraud and data theft risk, and can make attacker activity appear legitimate in managed device logs.

[Read More](#)

■ March 31, 2026

FortiClient EMS Flaw Threatens Retail

Active exploitation of CVE-2026-21643 in FortiClient EMS lets attackers use pre-authentication SQL injection to access databases, credentials, endpoint inventory, policies, and certificates. For retail trade, internet-exposed EMS systems are likely to face mass scanning, broader endpoint compromise, and operational disruption.

[Read More](#)

■ March 30, 2026

Notable Developments

Trivy Backdoor Hits Retail Pipelines

A trojanized Trivy release stole GitHub, Amazon Web Services (AWS), Secure Shell (SSH), and Kubernetes credentials from CI/CD pipelines after a maintainer account compromise. For retail trade, this creates realistic risk of cloud access, lateral movement, and data theft across e-commerce, payment, and inventory systems using the affected scanner or GitHub Actions.

[Read More](#)

■ March 20, 2026

Zendesk Impersonation Threat Hits Retail

ReliaQuest found a surge in fake Zendesk domains used for phishing, credential theft, and account takeover. For retail trade, compromised support-platform or single sign-on credentials can expose customer communications, ticketing systems, and connected workflows, raising fraud, data exposure, and operational disruption risks.

[Read More](#)

■ March 9, 2026